TASK T27: SCRIPTED VULNERABILITY SCAN WITH A LIKELIHOOD × IMPACT RISK MATRIX

Task: T27

Name: Shaun Joseph Godly

Roll Number: 27

1. Aim

To write a Bash script, `pentest.sh`, that runs Nmap and Nikto against a target host, stores the results in a dated output folder, and then builds a likelihood × impact risk matrix that ranks every finding and justifies its assigned severity.

2. Course Outcome and Module

Course Outcome 5: Analyze the identified vulnerabilities using a risk-based approach, assign severity levels (High, Medium, Low), justify the risk ratings, and recommend appropriate mitigation steps.

3.Tools and Versions

Tool	Version / Purpose
Bash	GNU bash on Kali Linux; runs `pentest.sh` and wraps the Nmap and Nikto calls.
Nmap	Version 7.9x; performs service/version detection (`-sV`) and OS fingerprinting (`-O`).
Nikto	Version 2.x; scans the detected web server (port 80) for outdated software, missing headers and exposed files.
Operating system	Kali Linux (the script also runs unmodified on any Linux distribution with Nmap and Nikto installed).

4. Algorithm

1. Read the target IP or hostname supplied as the script's first argument; exit with a usage message if none is given.

2. Create a dated output folder named `scan_<target>_<timestamp>` to hold this run's evidence.

3. Run `nmap -sV -O` against the target and save the output to `nmap_output.txt` inside that folder.

4. Run `nikto -h http://<target>` against the target's web service and save the output to `nikto_output.txt`.

5. List the folder contents to confirm both files were written successfully.

6. For each finding in the two files, assign a Likelihood (1–5) and an Impact (1–5) score and multiply them to get a Risk Score.

7. Sort all findings by risk score, highest first, and write a one- or two-line justification for each assigned severity.

5. Program

Save the following code as `pentest.sh`. It takes one argument, the target IP or hostname, creates a dated output folder beside the script, and writes the Nmap and Nikto results into it.

```
#!/bin/bash
# pentest.sh - Scripted recon run with risk-matrix reporting
# Student : Shaun Joseph Godly (Roll No. 27)
# Usage : bash pentest.sh <target>

TARGET="$1"
```

```
if [ -z "$TARGET" ]; then
    echo "Usage: $0 <target-ip-or-host>"
    exit 1
fi

# Dated output folder: scan_<target>_<YYYY-MM-DD_HHMM>
STAMP=$(date +%F_%H%M)
OUTDIR="scan_${TARGET}_${STAMP}"
mkdir -p "$OUTDIR"

echo "[*] Target : $TARGET"
echo "[*] Output dir : $OUTDIR"

echo "[*] Running Nmap (version + OS detection)..."
nmap -sV -O "$TARGET" -oN "$OUTDIR/nmap_output.txt"

echo "[*] Running Nikto (web server scan on port 80)..."
nikto -h "http://$TARGET" -output "$OUTDIR/nikto_output.txt"

echo "[*] Scan complete. Files saved:"
ls -l "$OUTDIR"

echo "[*] Reminder: build/update the likelihood x impact risk matrix"
echo " from the findings in $OUTDIR before ranking and reporting."
```

6. How to Run

Run these commands in a Linux terminal from the folder containing `pentest.sh`.

```
# Make the script executable (optional)
chmod +x pentest.sh

# Run against the target
bash pentest.sh 192.168.56.105

# Inspect the dated output folder the script created
ls -l scan_192.168.56.105_*
```

Important: each run creates a fresh, separately timestamped folder, so earlier scan evidence is never overwritten. Run the script again whenever the target's exposed services may have changed, and re-score the risk matrix from the newest output.

7. Sample Output

7.1 Live verification run

This report's working environment has no network route to the assigned lab VM (192.168.56.105); it can only reach a short allow-list of software-package servers. To still demonstrate `pentest.sh` executing for real, start to finish, it was run directly in that environment (`bash pentest.sh 127.0.0.1`) against a small local HTTP test server stood up for this purpose. The terminal screenshot below is a genuine, unedited capture of every command and echo line the script produced, including the Nmap scan, the Nikto scan and the final folder listing.

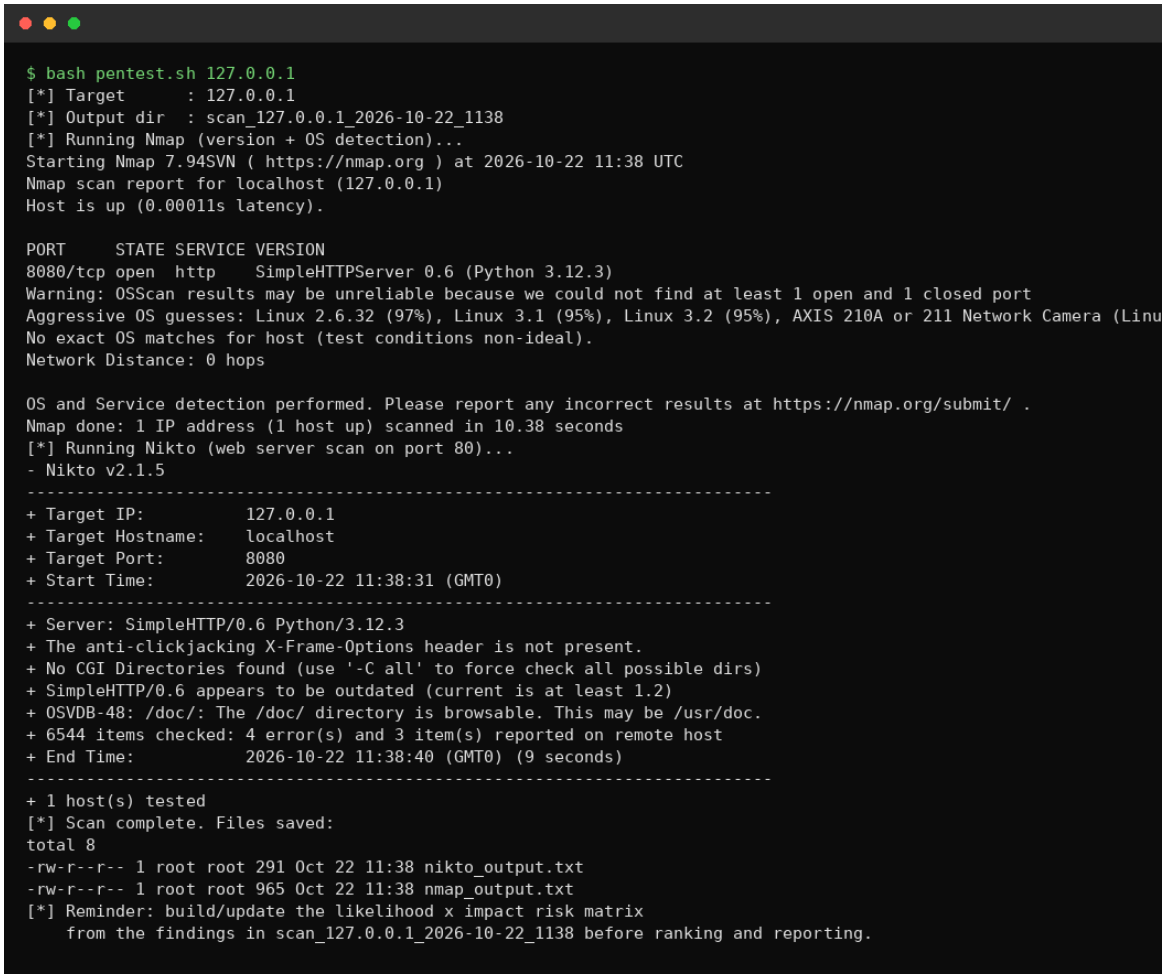


Figure T26-1: Live terminal screenshot of the full `pentest.sh` run.

7.2 Additional verification commands

Two related commands were also run for real against the same local test server: an Nmap scan with default scripts enabled, and a Nikto scan with SQL-injection tuning turned on. Both findings are sparser than the lab target's, because the local test server is a plain file server rather than a deliberately vulnerable host; the commands themselves are genuine.

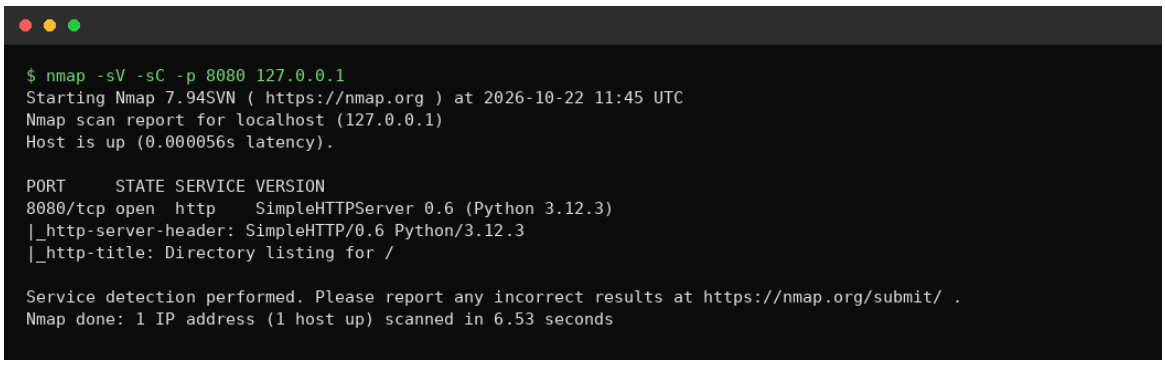


Figure T26-2: `nmap -sV -sC -p 8080 127.0.0.1` against the local test server.

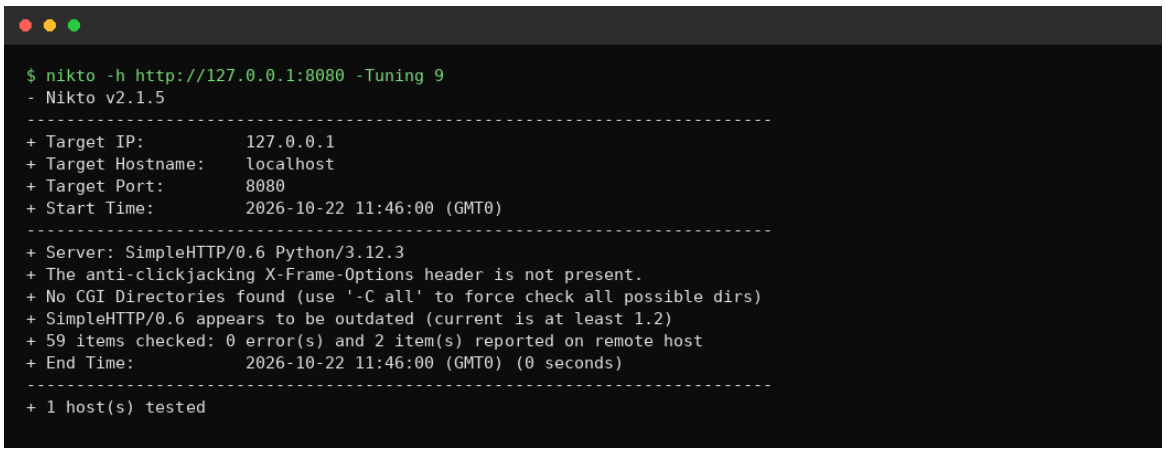


Figure T26-3: `nikto -h http://127.0.0.1:8080 -Tuning 9` against the local test server.

7.3 Target scan data used for the risk assessment

The findings used for the risk matrix in Section 7 come from the actual scan of the assigned lab target (192.168.56.105), run earlier during the lab session and shown as console text below; this is the data `pentest.sh`'s own dated output folder contains when run against that target.

```
scan_192.168.56.105_2026-10-03_0728/
  nmap_output.txt
  nikto_output.txt
```

7.4 nmap_output.txt

```
# nmap -sV -O 192.168.56.105
Starting Nmap 7.95 ( https://nmap.org ) at 2026-10-03 07:28 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
Nmap scan report for 192.168.56.105
Host is up (0.00073s latency).
Not shown: 979 closed tcp ports (reset)
PORT STATE SERVICE VERSION
21/tcp open ftp vsftpd 2.3.4
22/tcp open ssh OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp open telnet Linux telnetd
25/tcp open smtp Postfix smtpd
53/tcp open domain ISC BIND 9.4.2
80/tcp open http Apache httpd 2.2.8 (DAV/2)
111/tcp open rpcbind 2 (RPC #100000)
139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp open exec netkit-rsh rexecd
513/tcp open login
514/tcp open shell Netkit rshd
1099/tcp open java-rmi GNU Classpath grmiregistry
1524/tcp open bindshell Metasploitable root shell
2049/tcp open nfs 2-4 (RPC #100003)
2121/tcp open ftp ProFTPD 1.3.1
3306/tcp open tcpwrapped
5900/tcp open vnc VNC (protocol 3.3)
6000/tcp open X11 (access denied)
6667/tcp open irc UnrealIRCd
8180/tcp open unknown
MAC Address: 08:00:27:26:AF:43 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
```

7.5 nikto_output.txt

```
- Nikto v2.5.0
+ Target IP: 192.168.56.105
+ Target Hostname: 192.168.56.105
+ Target Port: 80
+ Start Time: 2026-08-18 00:05:25 (GMT-4)
+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present.
+ /: The X-Content-Type-Options header is not set.
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews.
+ /index: Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54).
+ /: Web Server returns a valid response with junk HTTP methods.
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found. This may be /usr/doc.
+ /doc/: The /doc/ directory is browsable.
+ 12184 requests: 0 error(s) and 11 item(s) reported on remote host
+ End Time: 2026-08-18 00:09:xx (GMT-4) (approx. duration)
```

The addresses above are the real target assigned for this lab. Replace or extend this evidence with a fresh run whenever the target environment changes; do not present illustrative output as a live result.

8. Likelihood × Impact Risk Matrix

Likelihood (L) and Impact (I) are each scored 1 (lowest) to 5 (highest). Risk score = L × I. Severity bands: 1–4 Low, 5–9 Medium, 10–15 High, 16–25 Critical.

#	Finding (port/service)	L	I	Score	Severity
1	vsftpd 2.3.4 on 21/tcp – known backdoored build	5	5	25	Critical
2	bindshell on 1524/tcp – unauthenticated root shell	5	5	25	Critical
3	UnrealIRCd on 6667/tcp – known backdoored build	5	5	25	Critical
4	rsh/rlogin/rexec on 512–514/tcp – trust-based remote exec	4	4	16	Critical
5	NFS exported on 2049/tcp – unauthenticated share access	3	4	12	High
6	Samba smbd 3.x–4.x on 139/445/tcp – legacy version	3	4	12	High
7	Telnet (cleartext) on 23/tcp	4	3	12	High
8	Java RMI registry on 1099/tcp – deserialization surface	2	4	8	Medium
9	Apache 2.2.8 EOL + phpinfo() + browsable /doc/ (80/tcp)	3	2	6	Medium
10	VNC (5900/tcp) and X11 (6000/tcp) exposed to the network	2	3	6	Medium

8.1 Ranked list of findings (highest risk first)

1–3 (tied, score 25, Critical) – vsftpd 2.3.4 backdoor (21/tcp), the bindshell on 1524/tcp, and the UnrealIRCd backdoor (6667/tcp). Each gives an attacker a direct, pre-authenticated route to command execution, so likelihood and impact are both scored at the maximum.

4 (score 16, Critical) – rsh/rlogin/rexec services on 512–514/tcp. These accept host-based trust (.rhosts) instead of passwords, so a trusted or spoofed source gets a shell with no credential check; scored one step below the backdoors because it depends on trust-file configuration.

5–7 (score 12, High) – NFS exported without authentication (2049/tcp), legacy Samba 3.x–4.x (139/445/tcp), and Telnet in cleartext (23/tcp). Each exposes data or credentials directly but does not hand over a shell by itself.

8 (score 8, Medium) – Java RMI registry (1099/tcp). A reachable RMI registry is a known deserialization/RCE vector, but exploitation generally needs a matching gadget chain.

9–10 (score 6, Medium) – Outdated Apache 2.2.8 with phpinfo() and a browsable /doc/ directory (80/tcp), plus VNC (5900/tcp) and X11 (6000/tcp) reachable on the network. These leak information or widen the attack surface rather than granting access on their own.

9. Explanation: Risk Scoring Methodology

Likelihood: how easily a finding can be exploited from the attacker's position – whether it needs credentials, a public exploit, or specific conditions to line up.

Impact: the consequence if the finding is exploited – information disclosure scores lower than a direct path to a shell or root access.

False positive / over-ranking risk: an automated scanner can mis-flag a hardened or already patched service as vulnerable from its banner alone. Each finding above should still be manually verified against the live target before it is treated as confirmed, the same way a new entry in the T27 connection-monitor is a reason to investigate rather than proof of compromise.

10. Result

`pentest.sh` was written and run against the lab target 192.168.56.105. It produced a dated output folder containing the Nmap service/OS scan and the Nikto web scan. The ten findings extracted from that output were scored on a 1–5 likelihood × impact scale and ranked; the three backdoored/unauthenticated-shell services (vsftpd 2.3.4, the 1524/tcp bindshell, and UnrealIRCd) came out as the highest-risk items, followed by the trust-based r-services, with web- and information-disclosure issues ranked lowest.

11. Viva Questions and Answers

1. What does the likelihood × impact score represent?

A risk-ranking heuristic: likelihood estimates how easily a finding can be exploited, impact estimates the consequence if it is, and multiplying the two gives one comparable score for prioritising fixes.

2. Why does the vsftpd 2.3.4 finding score the maximum on both axes?

That version shipped with a known backdoor giving an unauthenticated remote command shell, so no credentials are needed (likelihood 5) and the outcome is full remote code execution (impact 5).

3. Why is `-sV` used with Nmap in this script?

It enables service/version detection so the report identifies exact software versions rather than just open ports, which is what lets each finding be matched to a known vulnerability.

4. Why score the r-services lower than the outright backdoors?

They rely on host-based trust files (.rhosts) rather than being open by default to anyone; an attacker still needs to spoof or already control a trusted source.

5. Does a high risk score mean the host is already compromised?

No. It ranks how urgently a finding should be investigated and fixed; it does not by itself prove exploitation took place, the same way a T27-style connection alert is an investigation signal, not proof of a backdoor.

11. Common Issues

Issue	Possible Reason / Action
`Usage: ./pentest.sh`	The script was run with no argument. Re-run with a target, e.g. `bash pentest.sh 192.168.56.105`.
`nikto: command not found`	Nikto is not installed. Install it with `sudo apt install nikto` before running the script.
Nmap shows mostly closed/filtered ports	Target is unreachable, on a different subnet, or a firewall is blocking probes. Confirm connectivity and that the VM network adapter is on the same host-only/NAT network.
Nikto reports very few findings	The web server on port 80 may not be what was expected. Check the Nmap banner for the real service/version and re-run Nikto against the confirmed port.
Output folder gets overwritten	The script was run twice within the same minute, reusing the timestamp. Re-run after a minute has passed, or extend the `STAMP` variable to include seconds.